Incident Response Playbooks
By
Oluwatobi Babalola

Phishing | Account Compromise | Ransomware

Classification: CONFIDENTIAL

Framework: NIST SP 800-61

PLAYBOOK 1 Phishing Email	PLAYBOOK 2 Account Compromise	PLAYBOOK 3 Ransomware / Malware

These playbooks follow the NIST SP 800-61 incident response lifecycle: Prepare → Detect & Analyse → Contain, Eradicate & Recover → Post-Incident. They are derived from incidents investigated during the SecOps Sprint (Tasks 1, 2, and 3) and are aligned to the IncidentResponse.com Malware Outbreak Playbook structure provided as the reference template.

PLAYBOOK 1

Phishing Email Incident

Based on: Task 2 — Active Email Threat Investigation | NIST SP 800-61

SEVERITY	Ranges from LOW (spam/unsolicited) to CRITICAL (confirmed malware delivery or credential harvesting targeting high-value users). Escalate to CRITICAL if payload confirmed malicious or user clicked link.

PHASE 1 — PREPARE

1.1 Core Response Team

Role	Responsibility	Contact / Escalation
SOC Analyst (L1)	Initial triage — review alert, collect email headers and URLs, submit to threat intel tools	On-call SOC rotation
SOC Analyst (L2)	Deep investigation — header analysis, IOC extraction, verdict determination	Escalate from L1
Incident Response Lead	Coordinate response, approve containment actions, manage comms	IR Lead on-call
IT Infrastructure	Email gateway block implementation, mail flow rule deployment	IT helpdesk / infra team
CISO	Notified for HIGH/CRITICAL incidents involving confirmed malware or VIP targets	Executive escalation path
Legal / DPO	Notified if personal data potentially exposed — UK GDPR obligations	Legal / Data Protection Officer

1.2 Pre-Requisite Tools

- ☐ VirusTotal — URL, domain, hash reputation analysis
- ☐ URLScan.io — URL behaviour and redirect chain analysis

- ☐ Email header analyser (e.g. MXToolbox, Google Admin Toolbox)
- ☐ SIEM (Microsoft Sentinel) — search mail flow logs and proxy logs
- ☐ Email gateway admin access (Cisco ESA / Microsoft Defender for Office 365)
- ☐ Threat intelligence platform — IOC lookup and tagging

PHASE 2 — DETECT & ANALYSE

2.1 Threat Indicators

Indicator	Severity
Email from unknown external sender using personal Gmail or spoofed domain	Low–High
Display name spoofing — From shows internal colleague name but external address	High
Link in email points to paste site, file download, or redirect chain	High
Attachment is an archive (RAR, ZIP) containing an executable	Critical
Email bypassed AV but triggered behavioural EDR alert	Critical
UUID or machine-generated sender address	High
Source domain is recently registered or bulk-mail infrastructure	Medium
Email targeting VIP or finance/IT staff with role-specific pretext	High
Multiple staff receiving similar emails within same time window	Critical — coordinated campaign

2.2 Investigation Steps

- ☐ Collect the reported email — obtain .eml file or forward as attachment from reporter
- ☐ Extract and document: sender address, Reply-To, Return-Path, all Received headers, SCL score, DKIM/SPF/DMARC results
- ☐ Identify display name vs actual sender address — check for spoofing

- ☐ Extract all URLs from email body and HTML source — check for href vs display text discrepancy (URL masking)
- ☐ Submit all URLs and domains to VirusTotal and URLScan.io — document results with screenshots
- ☐ Submit any file attachments or hashes to VirusTotal — document malware family if detected
- ☐ Check if multiple staff received the same or similar email — search SIEM mail logs for sender domain/IP
- ☐ Check proxy/firewall logs for any outbound connections to identified malicious URLs from reporter's device
- ☐ Determine verdict: Benign / Spam / Suspicious / Confirmed Malicious
- ☐ Document all IOCs: sender email, domains, IPs, URLs, file hashes

2.3 Risk Factors

- ☐ User has clicked the link or opened the attachment — assume compromise if confirmed
- ☐ Targeted user has elevated privileges or access to sensitive data (VIP, Finance, IT, HR)
- ☐ Email contains a credential harvesting page or malware payload
- ☐ Multiple staff targeted in coordinated campaign — indicates prior reconnaissance
- ☐ Payload bypassed email gateway AV — gap in detection coverage identified
- ☐ Email impersonates internal colleague or trusted brand (Adobe, Microsoft, etc.)

PHASE 3 — CONTAIN, ERADICATE & RECOVER

3.1 Containment

- ☐ Block sender email address at email gateway
- ☐ Block sender domain at email gateway
- ☐ Block all malicious URLs and domains at web proxy and DNS filter
- ☐ Block malicious file hashes in EDR/antivirus
- ☐ If user clicked link or opened payload: isolate device from network immediately
- ☐ Search SIEM/email logs for all recipients of the same campaign — identify any additional affected users

- ☐ Apply mail flow rule to quarantine any further emails from the identified campaign infrastructure
- ☐ Notify all recipients of the phishing email — advise not to click links or open attachments

3.2 Eradication

- ☐ Remove phishing email from all affected mailboxes using email admin tools (Microsoft Purview Content Search / Compliance portal)
- ☐ Verify removal across all mail clients including mobile devices
- ☐ If payload was executed: run full EDR scan on affected device
- ☐ Reset credentials for any user who may have entered credentials on a harvesting page
- ☐ Review and update email gateway rules to catch similar campaigns
- ☐ If credential harvesting confirmed: check for unauthorised logins in Entra ID / Azure AD sign-in logs

3.3 Recovery

- ☐ Confirm all malicious emails have been removed from all mailboxes
- ☐ Confirm affected device is clean before reconnecting to network
- ☐ Re-enable any temporarily suspended user accounts after credential reset and device verification
- ☐ Update threat intelligence platform with all IOCs from this incident
- ☐ Create custom Sentinel alert rules for the identified IOCs

3.4 Communications

- To affected user(s): Notify of investigation outcome, advise on actions taken, provide guidance on what to watch for. Keep non-technical language.
- To IT Infrastructure: Provide IOC list for gateway and proxy blocks. Request confirmation of implementation.
- To CISO (if HIGH/CRITICAL): Brief on incident scope, affected users, payload type, and actions taken.
- To Legal/DPO (if data exposed): Notify for UK GDPR assessment — 72-hour notification window may apply.

PHASE 4 — POST-INCIDENT

4.1 Lessons Learned Review

- ☐ Was the phishing email detected by the email gateway or only by user report / EDR?
- ☐ Was there a gap between email receipt and user report — could earlier detection have prevented harm?
- ☐ Did the email gateway's AV scanner miss the payload? If so, what additional controls would have caught it?
- ☐ Were the IOCs added to threat intelligence in a timely manner?
- ☐ Were communications to affected users clear, timely, and appropriate?
- ☐ Should phishing simulation training be updated to include the techniques used in this campaign?

4.2 Policy & Configuration Updates

- ☐ Update email gateway rules based on campaign characteristics
- ☐ Review and update ASR rules and Defender for Office 365 policies
- ☐ Add all campaign IOCs to Sentinel watchlist and custom alert rules (Task 8)
- ☐ Update phishing awareness training materials if new techniques were used
- ☐ Document incident in incident register with full timeline, IOCs, and actions taken

PLAYBOOK 2

Account Compromise / Suspicious Sign-In

Based on: Task 3 — Suspicious Sign-In Investigation | NIST SP 800-61

SEVERITY	CRITICAL if successful login from foreign/hosting IP confirmed. HIGH if multiple failed attempts. Escalate immediately if sensitive data was accessed or exfiltrated post-login.

PHASE 1 — PREPARE

1.1 Core Response Team

Role	Responsibility	Contact / Escalation
SOC Analyst (L1)	Initial alert triage — review sign-in logs, identify anomalous IPs	On-call SOC rotation
SOC Analyst (L2)	IP geolocation, VT analysis, activity log correlation, verdict	Escalate from L1
Identity & Access Admin	Credential reset, session revocation, MFA enforcement, Conditional Access	IAM team / Azure AD admin
Incident Response Lead	Coordinate response, scope assessment, stakeholder comms	IR Lead on-call
CISO	Notified for confirmed compromise — especially if sensitive data accessed	Executive escalation
Legal / DPO	Notified if personal data (e.g. payroll) was accessed or exfiltrated	Data Protection Officer

1.2 Pre-Requisite Tools

- ☐ Microsoft Entra ID (Azure AD) — sign-in logs, audit logs, Conditional Access
- ☐ ipinfo.io — IP geolocation and infrastructure type lookup
- ☐ VirusTotal — IP reputation, crowdsourced threat intelligence

- ☐ Microsoft Sentinel — SIEM correlation of sign-in and activity logs
- ☐ Microsoft 365 compliance portal — activity audit logs, data access review
- ☐ Defender for Identity — impossible travel detection, unfamiliar sign-in properties

PHASE 2 — DETECT & ANALYSE

2.1 Threat Indicators

Indicator	Severity
Login from IP geolocated outside expected country (UK for this org)	High
Login from hosting/VPS/bulletproof hosting IP — not a consumer ISP	Critical
Multiple failed login attempts followed by success — brute force pattern	Critical
Concurrent sessions from geographically impossible locations (impossible travel)	Critical
Login from known malicious IP — VT detections or crowdsourced reports	Critical
Login at unusual hours outside normal working pattern for the user	Medium
Login to sensitive applications (Azure CLI, SharePoint, admin portals) from unusual IP	High
Malformed or non-standard Request ID in sign-in log — indicator of automated tooling	High
File access or download of sensitive documents shortly after suspicious login	Critical

2.2 Investigation Steps

- ☐ Export sign-in logs for the affected user for the investigation period
- ☐ Establish baseline: identify the user's normal IP(s), working hours, and application usage pattern
- ☐ Identify all IP addresses deviating from the baseline

- ☐ Submit each suspicious IP to ipinfo.io — document country, city, ISP, and infrastructure type (ISP vs hosting vs VPS)
- ☐ Submit each suspicious IP to VirusTotal — document vendor detections, community score, and crowdsourced behaviours
- ☐ Flag any IPs classified as hosting/VPS rather than consumer ISP — these are not normal user IPs
- ☐ Cross-reference suspicious IP logins against activity logs — identify what was accessed, modified, or downloaded post-login
- ☐ Check Request IDs for malformed UUIDs — indicator of automated tooling
- ☐ Determine whether the legitimate user was also active during the same period — concurrent sessions confirm credential theft not account takeover
- ☐ Document all findings, timeline, and verdict

2.3 Risk Factors

- ☐ Attacker successfully authenticated — session was active, not just attempted
- ☐ Attacker accessed sensitive files (financial data, HR records, security documentation)
- ☐ Attacker downloaded files — data exfiltration confirmed
- ☐ Attacker attempted to access admin tools (Azure CLI, admin portals)
- ☐ Attacker IP is confirmed malicious infrastructure (VT detections, bruteforce history)
- ☐ Compromised user has elevated privileges or access to sensitive systems
- ☐ No MFA in place — credential alone was sufficient for access

PHASE 3 — CONTAIN, ERADICATE & RECOVER

3.1 Containment

- ☐ Immediately reset the compromised user's password
- ☐ Revoke all active sessions for the compromised account across all Microsoft 365 services
- ☐ Enforce MFA re-registration — invalidate existing MFA tokens
- ☐ Block all identified malicious IPs in Conditional Access policies and at the firewall
- ☐ Implement Conditional Access policy blocking logins from outside expected country/region if not already in place

- ☐ Place the compromised account under enhanced monitoring — alert on any login from non-UK IP
- ☐ If sensitive data was accessed: notify the DPO and begin UK GDPR breach assessment immediately
- ☐ Check whether the same IPs attempted to access other accounts — search SIEM for cross-account activity

3.2 Eradication

- ☐ Determine the credential theft vector — check if the user received a phishing email in the days prior to the first suspicious login
- ☐ If phishing email identified: treat as linked incident and apply Playbook 1 eradication steps
- ☐ Review affected user's device for unauthorised software (e.g. mouse jiggler, keylogger) that may have assisted credential theft
- ☐ Review all actions taken during the attacker's active session — identify all accessed, modified, or deleted resources
- ☐ If Azure CLI or admin tool access was attempted: audit all Azure/M365 configurations for unauthorised changes
- ☐ Remove any unauthorised software or persistence mechanisms identified on the user's device

3.3 Recovery

- ☐ Confirm credential reset and MFA re-enrollment complete before restoring access
- ☐ Restore access to the compromised account only after device has been verified clean
- ☐ Notify any staff whose data may have been accessed (e.g. payroll data) per UK GDPR requirements
- ☐ Recover any deleted or modified files from backup if tampering is confirmed
- ☐ Update threat intelligence with all IOCs from this incident
- ☐ Create Sentinel KQL detection rules for the identified malicious IPs and access patterns

3.4 Communications

- To compromised user: Notify of breach, explain actions taken (password reset, session revocation), advise on phishing vigilance.
- To CISO: Brief on confirmed compromise, data accessed, attacker infrastructure, and remediation status.

- To Legal/DPO: Notify if sensitive personal data (payroll, HR) was accessed — UK GDPR 72-hour notification window assessment required.
- To affected data subjects: If personal data confirmed exfiltrated, individual notifications required per UK GDPR Article 34.

PHASE 4 — POST-INCIDENT

4.1 Lessons Learned Review

- ☐ Was MFA enforced at the time of compromise? If not, would MFA have prevented the breach?
- ☐ Were Conditional Access policies in place to block foreign IP logins? If not, would they have stopped the attacker?
- ☐ How long between first suspicious login and detection? What reduced the detection window?
- ☐ Was the exfiltrated vulnerability report (if applicable) classified and protected with sensitivity labels?
- ☐ Were download alerts configured for sensitive documents? If not, would automated alerts have triggered earlier response?
- ☐ Was the credential theft vector (phishing) linked to a concurrent incident? Are the incidents being treated as a coordinated campaign?

4.2 Policy & Configuration Updates

- ☐ Implement Conditional Access policy: block logins from outside UK unless MFA challenge passed from known device
- ☐ Enable Microsoft Defender for Identity for impossible travel detection and unfamiliar sign-in property alerts
- ☐ Apply sensitivity labels to confidential documents (payroll, security reports) with download audit alerts
- ☐ Enforce phishing-resistant MFA (hardware token or passkey) for all privileged and high-value accounts
- ☐ Add all IOCs to Sentinel watchlist and create detection rules (Task 8)
- ☐ Document incident in incident register with full timeline and lessons learned

PLAYBOOK 3

Ransomware / Malware Delivery Incident

Based on: Task 4 — WannaCry Malware Analysis | NIST SP 800-61

SEVERITY	CRITICAL by default. Any confirmed ransomware delivery or execution is a major incident. Escalate immediately. Do not delay containment pending full analysis — speed is critical to limiting encryption spread.

PHASE 1 — PREPARE

1.1 Core Response Team

Role	Responsibility	Contact / Escalation
SOC Analyst (L1/L2)	Alert triage, initial IOC extraction, sandbox submission	On-call SOC rotation
Malware Analyst	Static and dynamic analysis, IOC extraction, MITRE mapping	Security team escalation
IT Infrastructure	Network isolation, firewall rules, SMB port blocking, patch deployment	IT infra on-call
Incident Response Lead	Overall coordination, containment decisions, stakeholder comms	IR Lead on-call — 24/7
CISO	Notified immediately for any confirmed ransomware — ransomware is a major incident by default	Executive escalation — immediate
Legal / DPO	Data breach assessment, UK GDPR notification, ransom payment legal advice	Legal counsel / DPO
Backup/Recovery Team	Data restoration from clean backups post-eradication	IT backup team

1.2 Pre-Requisite Tools & Preparedness

- ☐ Joe's Sandbox or Any.run — malware detonation in isolated environment

- ☐ VirusTotal — static hash analysis, IOC lookup
- ☐ ISOLATED analysis VM — never detonate malware on production or personal machines
- ☐ Offline, immutable backups — verified clean and tested regularly
- ☐ Network isolation capability — ability to immediately segment affected devices
- ☐ EDR solution (CrowdStrike, Defender for Endpoint) deployed across all endpoints
- ☐ MS17-010 patch status — confirm EternalBlue vulnerability is patched on all Windows systems
- ☐ SMBv1 disabled — confirm across entire estate
- ☐ Block list ready — ability to rapidly block IPs, domains, and hashes at gateway and firewall

PHASE 2 — DETECT & ANALYSE

2.1 Threat Indicators

Indicator	Severity
EDR alert firing on suspicious executable — especially from email attachment or download path	Critical
Email attachment is an archive (RAR/ZIP) containing an executable file	Critical
Executable named to impersonate legitimate Windows tool (e.g. diskpart.exe, svchost.exe)	Critical
Email gateway AV returned NEGATIVE but EDR behavioural alert fired	Critical — detection gap
Mass file renaming or new unknown file extension appearing across filesystem (e.g. .WNCRY)	Critical — active encryption
Ransom note files appearing in directories (@Please_Read_Me@.txt, README.txt)	Critical — encryption complete
Rapid spawn of hundreds of identical processes in EDR process tree	Critical — WannaCry/ransomware threading
Volume Shadow Copy deletion detected	Critical — recovery prevention
High outbound connection volume to port 445 — SMB scanning for lateral movement	Critical

Tor network connections or .onion address DNS lookups	Critical — C2 communication
UUID or machine-generated sender address with bulk mail routing infrastructure	High

2.2 Investigation Steps

- ☐ DO NOT execute the suspicious file on any non-isolated machine
- ☐ Collect the EDR alert details: file name, path, hash, triggering behaviour
- ☐ Submit file hash to VirusTotal — document vendor score, malware family, all three hashes (MD5/SHA-1/SHA-256)
- ☐ Check VT Behaviour tab for MITRE ATT&CK mapping, dropped files, and network indicators
- ☐ Submit file to Joe's Sandbox (isolated detonation) — document process tree, dropped files, network activity, persistence mechanisms
- ☐ Identify the delivery vector: email attachment, malicious download, lateral movement from another infected host
- ☐ If delivered via email: apply Playbook 1 investigation steps to the delivery email
- ☐ Extract all IOCs: file hashes, C2 domains/IPs, Tor onion addresses, registry keys, dropped filenames
- ☐ Determine ransomware family — check for known kill switch or decryption tools before proceeding
- ☐ Check whether the file was executed — review EDR execution logs and file system for dropped files or .encrypted extensions

2.3 WannaCry-Specific Analysis Notes

- ☐ Kill switch domain: www.iuqerfsodp9ifjaposdfjhgosurijfaewrwergwea.com — if this domain resolves, WannaCry stops. Consider allowing DNS resolution rather than blocking.
- ☐ WannaCry key dropped files: @WanaDecryptor@.exe, @Please_Read_Me@.txt, taskdl.exe, taskse.exe, u.wnry, c.wnry, *.WNCRY
- ☐ WannaCry persistence: HKLM\SOFTWARE\WannaCrypt registry key, Startup folder file write
- ☐ WannaCry lateral movement: port 445 SMB scanning — exploit MS17-010 (EternalBlue) on unpatched hosts
- ☐ WannaCry C2: Tor onion addresses embedded in binary and c.wnry resource file

- ☐ Do not pay ransom — WannaCry payment infrastructure was disrupted in 2017, decryption keys not reliably delivered

PHASE 3 — CONTAIN, ERADICATE & RECOVER

3.1 Containment — IMMEDIATE

- ☐ ISOLATE affected device immediately — disconnect from all network connections (wired and wireless)
- ☐ DO NOT shut down the device — live memory may contain encryption keys recoverable by forensics
- ☐ Block port 445 (SMB) inbound/outbound at network perimeter — prevents WannaCry lateral movement
- ☐ Block all identified malicious IPs, domains, and Tor onion addresses at firewall and DNS filter
- ☐ Block file hash in EDR to prevent execution on any other endpoints
- ☐ Block sender domain and email address at email gateway
- ☐ Search EDR logs for the file hash across all endpoints — identify any additional affected machines
- ☐ Disable SMBv1 across the entire environment if not already done
- ☐ Alert all staff: do not open attachments or click links in unexpected emails — reference active campaign

3.2 Eradication

- ☐ Scan all endpoints for the confirmed file hash and known ransomware dropped files using EDR
- ☐ Check all systems for WannaCry registry key: HKLM\SOFTWARE\WannaCrypt
- ☐ Remove startup folder persistence file (~SDCE9B.tmp or equivalent) from all affected systems
- ☐ Patch MS17-010 (EternalBlue) on all unpatched Windows systems — critical to prevent re-infection via lateral movement
- ☐ Apply July 2023 Patch Tuesday updates (Task 5 action plan) — addresses Office/Windows vulnerabilities used in similar campaigns
- ☐ Remove phishing delivery email from all mailboxes (if delivered via email) per Playbook 1

- ☐ Wipe and reimage confirmed infected systems — do not attempt in-place cleanup of ransomware-encrypted systems

3.3 Recovery

- ☐ Restore encrypted files from most recent clean backup taken before infection timestamp
- ☐ Verify backup integrity before restoration — confirm backups themselves are not infected
- ☐ Rebuild any fully compromised systems from clean images
- ☐ After restoration: verify all systems are patched to MS17-010 level before reconnecting to network
- ☐ Conduct full network scan to confirm no remaining WannaCry persistence before declaring eradication complete
- ☐ Re-enable affected user accounts and restore access only after device verification and credential reset
- ☐ Update IDS/IPS and firewall rules with all IOCs from this incident

3.4 Communications

- To affected user (immediate): Do not use device, do not attempt to open files, contact security team immediately.
- To CISO (immediate): Ransomware confirmed — brief on scope, spread assessment, containment actions in progress.
- To all staff (within 1 hour): Security alert — do not open unexpected attachments. IT team investigating active threat.
- To Legal/DPO: Data breach assessment — confirm what data was on affected systems and whether encryption constitutes a notifiable breach under UK GDPR.
- To IT Infrastructure: Immediate action required — SMB port block, hash block, patch deployment schedule.

PHASE 4 — POST-INCIDENT

4.1 Lessons Learned Review

- ☐ Was the ransomware caught by the email gateway or only by EDR behavioural detection? Was there a detection gap?
- ☐ How much time elapsed between delivery and detection? Was the file executed before detection?

- ☐ Were offline, immutable backups available and current? What was the recovery time?
- ☐ Were MS17-010 and other relevant patches applied? If not, why?
- ☐ Was SMBv1 disabled? If WannaCry spread laterally, SMBv1 was enabled on additional hosts.
- ☐ Were Defender for Office 365 and Safe Attachments policies in place? Would they have blocked the archive attachment?
- ☐ Did the incident originate from the same threat actor as the concurrent phishing and account compromise incidents?

4.2 Policy & Configuration Updates

- ☐ Block archive attachments containing executables at email gateway — RAR/ZIP files containing .exe, .bat, .vbs should be sandboxed or blocked
- ☐ Deploy Microsoft Defender for Office 365 Safe Attachments in Block mode across all mailboxes
- ☐ Enforce offline immutable backup policy — 3-2-1 rule: 3 copies, 2 different media, 1 offsite
- ☐ Implement patch management SLA from Task 5: Critical patches (CVSS 9.0+) within 7 days, Emergency (actively exploited) within 48 hours
- ☐ Confirm SMBv1 is disabled across the full estate via Group Policy
- ☐ Add all IOCs to Sentinel watchlist and create detection KQL rules (Task 8)
- ☐ Conduct post-incident tabletop exercise with all relevant teams
- ☐ Document incident in incident register with full timeline, IOCs, and lessons applied